

NetFRAME Home Lab

Security Assessment Report

Public / Redacted Edition

July 13, 2026

Engagement	Authorized internal security assessment of an owner-operated home laboratory
Authorization	Full written authorization by the environment owner; strictly defensive; non-destructive
Scope	Owner-controlled hosts, network, virtualization, Kubernetes, storage, services, and repositories
Method	Passive + authenticated inspection, low-intensity enumeration, read-only auditors; no exploitation
Classification	Public: identifiers generalized, all secrets and addresses redacted

Contents

1	Executive Summary	2
2	Scope, Authorization, and Methodology	2
2.1	Authorization and rules of engagement	2
2.2	Coverage and intensity	2
2.3	Coverage gaps and limitations (stated honestly)	2
3	Attack Chains	3
4	Findings Register	3
4.1	Summary	3
4.2	HIGH-severity detail	4
4.3	Medium and lower findings	5
5	Positive Controls Confirmed	5
6	Prioritized Remediation Roadmap	5
	Appendix: Tooling and Evidence	6

1 Executive Summary

The NetFRAME home lab is built on a genuinely strong architectural foundation, and the assessment found no inbound Internet exposure, enforced network segmentation at Layer 3, an authenticated and encrypted cluster control plane, uniformly unprivileged containers, clean Kubernetes role bindings, and modern TLS across all services. These are not common findings in a home environment and reflect deliberate security engineering.

The risk in the environment is therefore not the perimeter; it is a set of **internal configuration gaps that chain together**. The single most important theme is that untrusted devices and an over-exposed administrative workstation share a Layer-2 segment with the management plane, while the highest-value credential on that workstation is unencrypted. A second theme is that several internal control surfaces (a container registry, the hypervisor firewall, an AI inference endpoint, and password-based root SSH) are open by default on the internal network, so an attacker who gains any internal foothold has an unusually short path to broad control.

Four HIGH-severity findings anchor the report, and their value is in how they combine (Section 3). No critical, Internet-exploitable exposure was identified.

Primary attack chain (all configuration, no exploit required). An untrusted IoT device or the network printer sits on the management VLAN (F-001). From there it can reach the administrator workstation's cleartext FTP, end-of-life SMB, and NFS services (F-003). Local read access on that workstation yields an *unencrypted* SSH private key that grants root across the entire cluster and signs commits (F-006). A twenty-dollar smart plug is thus three configuration steps from full cluster compromise.

2 Scope, Authorization, and Methodology

2.1 Authorization and rules of engagement

The assessment was performed under explicit written authorization from the environment owner, against only owner-controlled assets. It was strictly defensive and non-destructive: no exploitation, credential attacks, configuration changes, service restarts, or availability testing were performed. Where a weakness would normally require exploitation to confirm, it was validated analytically from configuration and version evidence instead. Third-party platforms (the code-hosting provider, the CDN, the mobile carrier, and the external AI API) were treated as out of scope except for review of the owner's own configuration.

2.2 Coverage and intensity

Testing intensity was held to passive and authenticated inspection, low-intensity host enumeration, and read-only security auditors. Evidence was recorded with commands and redacted output; secret values were never displayed. The assessment covered the network and segmentation, the firewall edge, host and operating-system hardening, the Proxmox virtualization and cluster identity layer, the Kubernetes/container platform, storage and backup, identity and secrets (local and repository), TLS, the application and AI layers, and monitoring.

2.3 Coverage gaps and limitations (stated honestly)

The following were not fully tested and are not represented as covered:

- **Core switch (the core switch):** not tested. Authentication to the switch CLI could not be reliably automated and the owner was remote; the switch-side confirmation of *why* untrusted devices are on the

management VLAN, plus Layer-2 protections (DHCP snooping, dynamic ARP inspection, BPDU/root guard, storm control, 802.1X) and switch firmware status, remain outstanding.

- **Kubernetes node-level CIS benchmark:** the control-plane nodes were not directly reachable by shell, so node-file checks (kube-bench, secrets-encryption confirmation, kubelet/etcd flags) were not performed.
- **Firmware and wireless testing:** out of authorized scope.
- **Detection efficacy:** monitoring components are present and healthy, but attack traffic was deliberately not generated, so rule efficacy against the specific chains was not exercised.
- **Cloudflare Access policy detail and per-application security headers:** require external-platform access / SNI resolution not available in this pass.

3 Attack Chains

Findings are most meaningful in combination. Four chains dominate the risk profile.

1. **IoT to cluster root:** F-001 → F-003 → F-006 (see Executive Summary).
2. **Service guest to hypervisor:** the hypervisor host firewall is fully disabled (VIRT-01) and the management API listens on all interfaces (VIRT-02), so a compromised service container has an unfiltered path to the node management port and SSH, where several hosts still permit password-based root login (HOST-01) with no brute-force protection (HOST-02).
3. **Supply chain:** the private container registry requires no authentication (K8S-01); because the cluster trusts it, an attacker who can reach it on the LAN can overwrite an image tag and achieve code execution across the cluster.
4. **Workstation to edge secrets:** the unencrypted workstation key (F-006) plus the firewall config-backup credential stored there (NET-06) expose the wildcard TLS private key and full firewall configuration.

4 Findings Register

Severity uses a qualitative scale informed by likelihood and technical/operational impact. CVSS-style vectors are indicative, not formal. Confidence is stated per finding.

4.1 Summary

ID	Sev	Conf	Finding
F-001	HIGH	Confirmed	Untrusted IoT/printer/mobile devices share Layer 2 with the management VLAN
F-003	HIGH	Confirmed	Admin workstation exposes cleartext FTP, end-of-life SMB, and NFS on that segment
F-006	HIGH	Confirmed	Unencrypted SSH keys granting cluster-wide root and commit signing
K8S-01	HIGH	Confirmed	Private container registry is anonymous (no authentication)

ID	Sev	Conf	Finding
VIRT-01	MED	Confirmed	Hypervisor datacenter/node firewall fully disabled
VIRT-02	MED	Confirmed	Hypervisor management API bound to all interfaces
VIRT-03	MED	Confirmed	Sole cluster admin is a shared superuser with no 2FA
NET-01	MED	Probable	OOB/BMC VLAN may initiate into management and server VLANs (asymmetric isolation)
NET-06	MED	Confirmed	Config-backup credential can export all firewall secrets incl. wildcard TLS key
HOST-01	MED	Confirmed	Password-based root SSH enabled on four hosts
F-007	MED	Confirmed	NFS exports use no_root_squash with UID-based auth
K8S-02	MED	Confirmed	No Kubernetes network policies (flat pod network)
K8S-03	MED	Confirmed	No Pod Security Admission on workload namespaces
K8S-04	MED	Low	Kubernetes secrets likely not encrypted at rest
AI-01	MED	Confirmed	LLM inference/router endpoint unauthenticated on the LAN
F-004	MED	Suspected	Unidentified host exposing X11 and FTPS
HOST-02	LOW	Confirmed	No brute-force/lockout protection (fail2ban inactive) anywhere
HOST-03	LOW	Confirmed	Pending security updates across hosts
HOST-04	LOW	Probable	NOPASSWD sudo entries to review
VIRT-04..06	LOW	Confirmed	No fail2ban; container nesting features; corosync authkey world-readable
NET-02/04/05	LOW	Confirmed	GUI on all interfaces; non-enforcing egress allowlist; appliances on mgmt VLAN
K8S-05/06	LOW	Confirmed	A dashboard over plaintext HTTP; default SA token automount
F-008	LOW	Confirmed	Storage encryption at rest disabled
NET-03	INFO	Confirmed	Default SNMP community present in config (daemon not running)
VIRT-07/08, AI-02	INFO	Confirmed	Non-expiring read-only token; leftover install media; a dashboard anon view

4.2 HIGH-severity detail

F-001 — Untrusted devices on the management VLAN (Confirmed). Evidence: the firewall’s ARP table and DHCP leases show several non-infrastructure devices holding management-VLAN addresses — multiple cloud smart plugs, a voice assistant, a network printer, and a personal mobile device. Only one such device is correctly placed on the IoT VLAN. Because same-VLAN traffic is not filtered by the firewall (which governs inter-VLAN only), these devices have direct Layer-2 reach to the hypervisor management plane, the core switch, and the cluster heartbeat. Root cause is Layer-2 placement (switch port / wireless SSID mapping), which bypasses an otherwise-correct Layer-3 segmentation design. *Impact:* High. *Remediation:* relocate all IoT, printer, and personal devices to the IoT/guest segments; enforce at the switch and DHCP; identify any unknown device.

F-003 — Legacy exposed services on the admin workstation (Confirmed). The administrator

workstation (WORKSTATION), multi-homed on the management VLAN, runs cleartext FTP, an end-of-life SMB implementation, NFS, and a web administration console, all reachable on the segment that F-001 shows also carries untrusted devices. Cleartext FTP credentials are sniffable and the SMB version is years past support. *Remediation:* disable FTP in favour of SFTP; restrict or remove SMB/NFS or bind them to a trusted host-only path; upgrade the SMB implementation.

F-006 — Unencrypted cluster-root SSH keys (Confirmed). The workstation holds SSH private keys with no passphrase; one authenticates as root across the whole cluster and also serves as the commit-signing key. File permissions are correct, but there is no second factor on the key material itself. Combined with F-003, an attacker with local read on the workstation obtains keys to the entire estate. *Remediation:* add passphrases (with an agent) or move to hardware-backed / short-lived certificate authentication; separate the signing key from the access key; reduce the access key's blast radius.

K8S-01 — Anonymous private container registry (Confirmed read; write inferred). The internal registry presents TLS but no authentication challenge; unauthenticated clients can enumerate and pull images, and no authentication layer is configured at all, so push is almost certainly permitted (not tested, as writing was out of scope). Because cluster nodes trust this registry, overwriting a tag yields cluster-wide code execution. *Remediation:* enable token or htpasswd authentication and image pull secrets; restrict network reachability to the cluster and CI only.

4.3 Medium and lower findings

The Medium findings (hypervisor firewall disabled, management API on all interfaces, shared superuser without 2FA, asymmetric OOB isolation, the config-backup credential's secret access, password root SSH on four hosts, permissive NFS, absent Kubernetes network policy and Pod Security Admission, likely-unencrypted secrets at rest, and the unauthenticated LLM endpoint) share a common theme: internal defaults are open, so lateral movement after any initial foothold is unusually easy. The Low and Informational findings (no brute-force protection, pending updates, sudo scope, container nesting features, corosync key permissions, GUI interface binding, a non-enforcing egress allowlist, appliances on the management VLAN, a plaintext dashboard, storage-at-rest encryption, and a latent default SNMP community) are hardening and hygiene items. Full per-finding evidence, impact, and remediation are maintained in the engagement findings register.

5 Positive Controls Confirmed

No inbound Internet exposure (no port-forwards; edge via an authenticated tunnel). Enforced inter-VLAN Layer-3 segmentation. Authenticated and encrypted cluster heartbeat. All containers unprivileged with no host-path mounts. Clean Kubernetes role bindings and least-privilege hypervisor API token. Grade-A TLS on all inspected services. Good secret-file permissions and no hardcoded secrets in scripts or shell history. A working SIEM and a mature alerting pipeline (including backup and quorum dead-man switches).

6 Prioritized Remediation Roadmap

1. **Now (breaks the primary chain):** move IoT/printer/mobile devices off the management VLAN (F-001); add passphrases to the SSH keys (F-006); disable cleartext FTP and legacy SMB on the workstation (F-003); add authentication to the container registry (K8S-01).
2. **Near term (shrink internal blast radius):** enable the hypervisor firewall with a default-deny input policy and bind the management API to the management interface (VIRT-01/02); disable password-based root SSH and deploy brute-force protection (HOST-01/02); add a dedicated admin account with

- 2FA (VIRT-03); constrain the OOB-to-management path (NET-01).
3. **Hardening:** Kubernetes default-deny network policy and Pod Security Admission (K8S-02/03); confirm and enable Kubernetes secrets encryption (K8S-04); authenticate the LLM endpoint (AI-01); tighten NFS squashing (F-007); apply pending updates and review sudo scope (HOST-03/04).
 4. **Follow-up:** complete the switch assessment when access is available; enforce the egress allowlist; rotate the config-backup credential and treat it as Tier-0 (NET-06); consider storage-at-rest encryption.

Appendix: Tooling and Evidence

Tools: `nmap` (connect scans, service and cipher enumeration), `gitleaks` (secret scanning), `trivy/kube-bench` (available; node-level checks not possible), authenticated configuration inspection via SSH and the hypervisor/Kubernetes APIs, and read-only firewall configuration review. Raw evidence (scan outputs, command logs, the findings register) is retained by the assessor with restrictive permissions and is not committed to any repository. Secret values were redacted throughout; where a credential was supplied for a test it was used transiently and stored nowhere.